Universidad Nacional Autonoma de Mexico

Facultad de Ingenieria

Alumno:

Lara Hernandez Angel Husiel - 320060829

Seguridad informatica basica

Grupo: 4

Semestre: 2027-1

Tarea 3

ATT&CKcon 7.0

Fecha de Entrega:

31 de Octubre del 2026

Indice

1 Charlas asistidas **1**

2 Experiencia personal y presentaciones **1**

2.1 Obfuscated Tale: From ATT&CK Origin to Detection Today 1

2.2 Multi-Tenant Kill Chain Correlation en entornos SaaS 3

2.3 The Defensible Minimum 3

2.4 MITRE ATT&CK Updates: Enterprise ATT&CK 5

2.5 Measuring ATT&CK Coverage Through Real Malware Tradecraft 7

2.6 Breaking the Defenders 7

3 Ejemplos del uso de ATT&CK en la industria **9**

4 Experiencia general y relacion con la materia **9**

5 Evidencia de participacion en el evento **10**

Referencias **13**

1. Charlas asistidas

Las charlas asistidas asistidias, fueron del dia 27 de octubre, siendo del primer dia de las conferencias, asistiendo desde las 9 de la mañana hasta las 3 de la tarde.

Para esto, se tuvieron 6 platicas, en las cuales entre medio de la 3 y 4, hubo un breve descanso.

Las seis charlas son las siguientes:

1. Obfuscated Tale: From ATT&CK Origin to Detection Today.
2. Multi-Tenant Kill Chain Correlation: ATT&CK-Stage Progression Scoring Across Identities and Organizations in SaaS Environments.
3. The Defensible Minimum: Threat-Informed Defense When You Can't Afford the Matrix.
4. MITRE ATT&CK Updates: Enterprise ATT&CK.
5. Measuring ATT&CK Coverage Through Real Malware Tradecraft: Beyond T1055.
6. Breaking the Defenders: Measuring Defense Impairment at Scale Through MSP Telemetry.

En general, algo que se repitio en las distintas ponencias fue que tener una tecnica marcada en una matriz no demuestra que realmente se pueda detectar. Esto me parecio importante por que en las practicas hemos identificado las acciones que se realizan durante un ataque, pero aqui se mostro que tambien se tiene que comprobar que informacion recibe el defensor y que puede hacer con ella.

2. Experiencia personal y presentaciones

2.1. Obfuscated Tale: From ATT&CK Origin to Detection Today

Empezo con la explicacion de que los atacantes pueden cambiar la forma en la que escriben o preparan un archivo, mientras que varias de las acciones que necesitan realizar siguen siendo parecidas.

Para esto, se mencionaron ejemplos con PowerShell, contenido codificado en Base64, para este caso, se nos explico que en el caso de Base64 sirve para representar informacion mediante otra codificacion y gzip para comprimirla.

Ahora bien, el punto que me parecio mas importante fue la diferencia entre registrar una accion y detectarla. Se puede tener el comando dentro de algun archivo, esto empezo siendo la parte principal, para poder ver desde donde inicia el ataque y aun asi no generar una alerta, por que todavia falta una regla que interprete lo que paso. Es donde entro el otro

tema a hablar, que fue el caso de la telemetria, que son los datos que se recolectan sobre la actividad del sistema, como los procesos que se crean, los scripts que se ejecutan y las conexiones que se realizan.

Despues de esto, se explico el uso de los eventos 4104 y 4103 de PowerShell, relacionados con el registro de bloques de script y de modulos. Tambien se menciono Sysmon, donde el evento 1 permite revisar la creacion de procesos, el 7 la carga de imagenes, incluyendo DLL, y el 17 la creacion de tuberias con nombre. Lo que se busca es relacionar los eventos para entender que programa inicio a otro y con que argumentos.

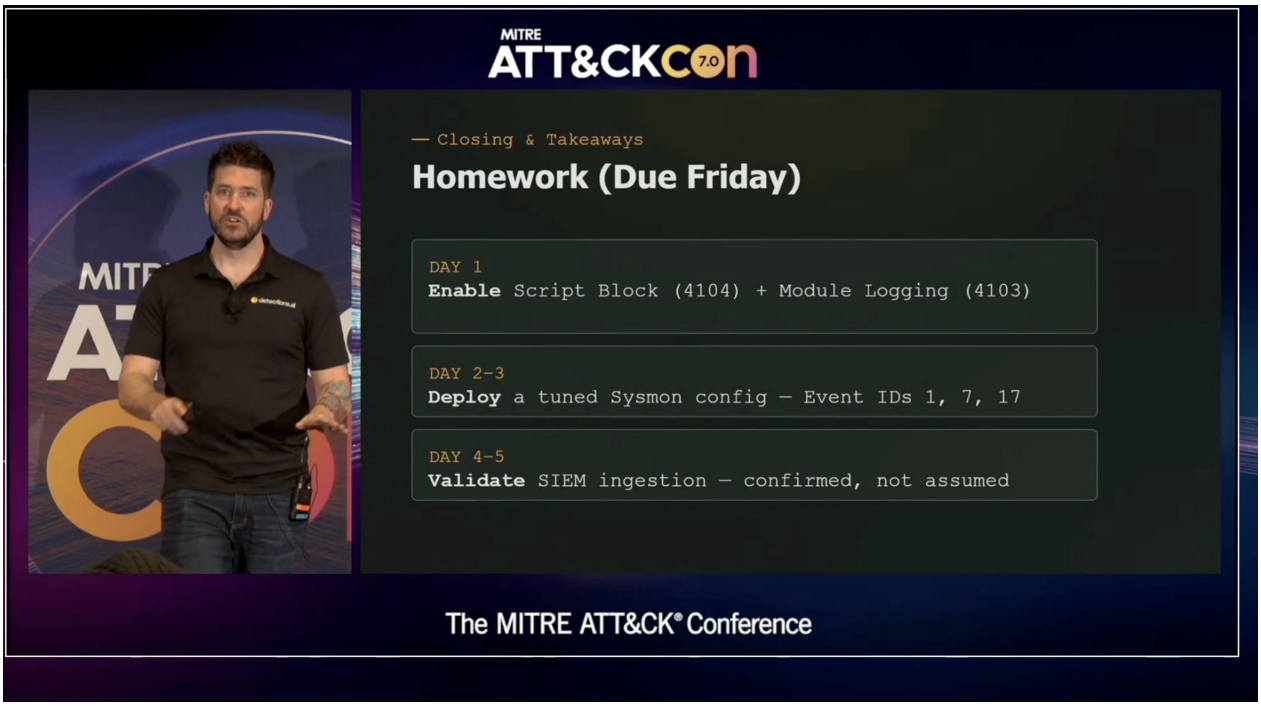

Figura 1: Recomendaciones sobre registros de PowerShell, Sysmon y validacion de la recepcion en el SIEM.

Elementos a destacar:

- Diferenciar entre tener un evento registrado y tener una deteccion que lo utilice.
- Revisar la relacion entre los procesos y no solamente una palabra dentro del comando.
- Comprobar que los registros realmente llegan al SIEM, que es la plataforma que permite reunirlos y analizarlos.

2.2. Multi-Tenant Kill Chain Correlation en entornos SaaS

En esta segunda presentacion se hablo de un problema distinto, pero relacionado con la misma idea: una alerta puede parecer poco importante si se revisa sola, mientras que al relacionarla con otras acciones puede mostrar una cadena de conexiones, lo que hace que sea tanto mas peligrosa, como se revele el patron de comportamiento de algun atacante o de los ataques. Se uso de ejemplo un SaaS, que son aplicaciones que se utilizan como un servicio.

Donde un tenant es el entorno de una organizacion dentro del servicio. La propuesta consistio en relacionar los eventos de una misma identidad a lo largo de un periodo y darles contexto segun las etapas de ATT&CK. Para esto, se trato como punto principal revisar si las acciones tenian una relacion que ayudara a explicar lo que estaba ocurriendo.

Algo a recalcar fue la diferencia entre una anomalia y una accion concreta. Por ejemplo, cambiar de proveedor de internet o de identificador del navegador puede ser algo extraño, pero no demuestra por si solo que una cuenta fue comprometida. Por otro lado, reutilizar un token de acceso, modificar la configuracion de autenticacion o cambiar una regla del correo son acciones que aportan otro tipo de evidencia. La anomalia ayuda a interpretar el caso, pero no debe reemplazar esa evidencia.

En lo personal, la parte que mas me intereso fue la correlacion entre organizaciones. Una integracion o una aplicacion de terceros puede tocar varios entornos, por lo que una secuencia de intentos fallidos en una sola empresa no siempre cuenta toda la historia. Si se encuentra el mismo patron en varios entornos y se relaciona con una identidad de integracion compartida, se puede ampliar la investigacion. Esto no significa que compartir una IP sea suficiente para afirmar que existe un ataque.

Elementos a destacar:

- Usar las etapas de ATT&CK para relacionar acciones de una misma identidad.
- Distinguir el contexto de una anomalia de la evidencia concreta de una accion.
- Combinar la correlacion entre organizaciones con las reglas y el conocimiento de los analistas.

2.3. The Defensible Minimum

El problema que planteo fue que no todas las organizaciones pueden mantener un centro de operaciones de seguridad completo, una herramienta en cada equipo y todos los registros que se quisieran tener.

Ahora bien, lo que me parecio importante fue que no se presento esto como una razon para dejar de defenderse. Se propuso identificar un minimo defendible, donde se toma lo que es importante para las amenazas de la organizacion y se compara con lo que realmente se puede

implementar, mantener y comprobar. Lo que queda fuera se tiene que reconocer como riesgo pendiente, en lugar de marcarlo como cubierto solamente por que aparece en una herramienta.

En lo personal, esto me hizo sentido con las practicas. Nosotros trabajamos con maquinas y herramientas especificas, por lo que cada resultado depende de lo que se configuro y de lo que se puede observar en ese entorno. Una herramienta instalada no demuestra por si misma que se este recibiendo toda la informacion necesaria. De igual forma, una organizacion pequeña puede empezar con sus accesos mas expuestos y con los registros que si tiene disponibles, sin fingir que ya resolvio todo lo demas.

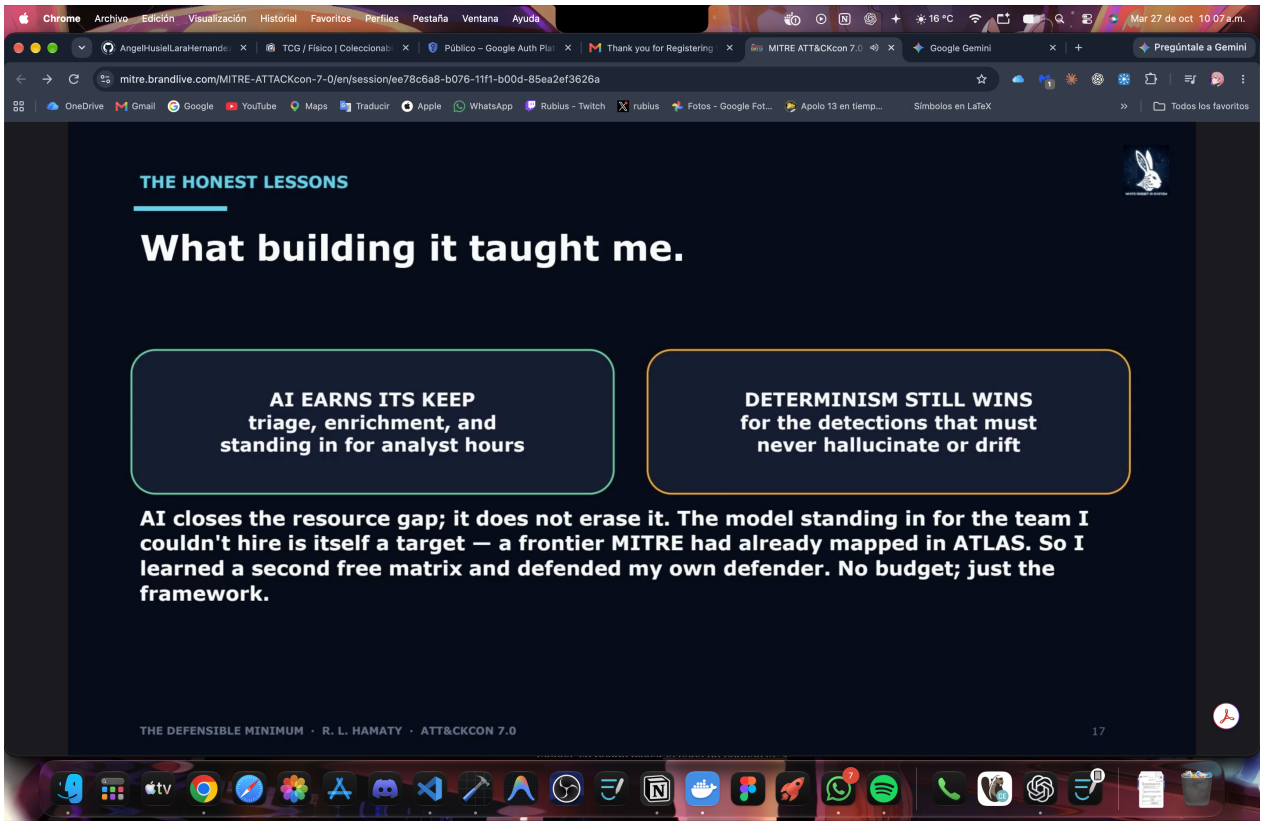

Figura 2: Uso de inteligencia artificial como apoyo y necesidad de detecciones comprobables.

Elementos a destacar:

- Priorizar lo que es importante y se puede sostener con los recursos disponibles.
- Reconocer el riesgo que queda pendiente y validar de forma continua los controles.

2.4. MITRE ATT&CK Updates: Enterprise ATT&CK

En esta charla se hablo de lo que se estaba preparando para la version 21 de ATT&CK, prevista para la primavera del 2027. Algo que me llamo la atencion fue que el contenido relacionado con inteligencia artificial, se explico que primero era necesario revisar su alcance y la evidencia del uso que le dan los adversarios.

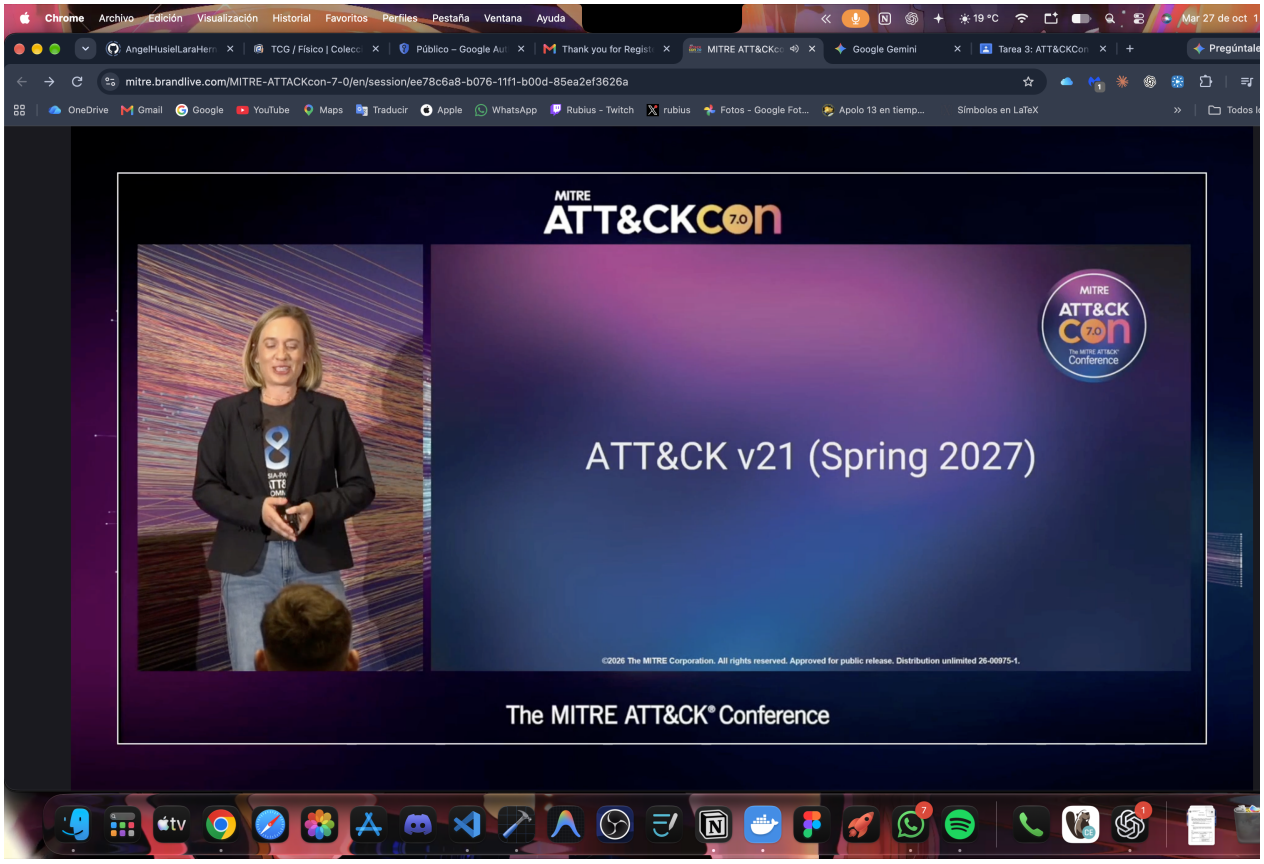

Figura 3: Presentacion de los planes para ATT&CK v21 en la primavera del 2027.

Para esto, se hablo de MITRE ATLAS, que organiza conocimiento sobre amenazas contra sistemas de inteligencia artificial. La propuesta era que los equipos de ATLAS y ATT&CK revisaran que comportamientos podian incorporarse en Enterprise ATT&CK. Donde en este caso, se aclaro que las demostraciones o pruebas de concepto no bastan por si solas para considerar que un comportamiento ya tiene uso adversario real.

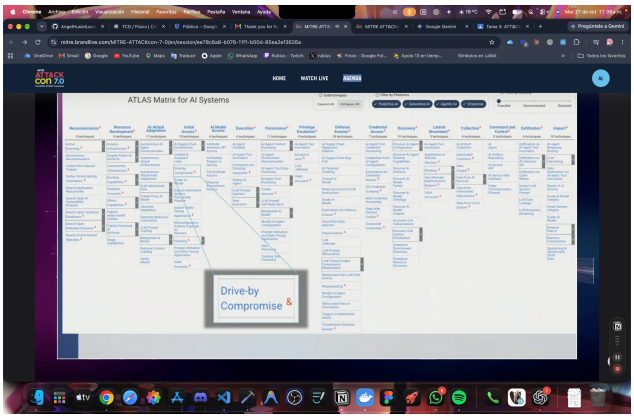

Figura 4: Matriz de ATLAS utilizada para explicar la relacion con Enterprise ATT&CK.

Despues de esto se explicaron varias posibilidades. Parte del contenido podria añadirse a una tecnica que ya existe, otra parte podria necesitar una nueva subtecnica o una tecnica especifica, y algunos comportamientos podrian permanecer fuera mientras no cumplan los criterios.

Un ejemplo fue el AI Artifact Repository, donde un repositorio de artefactos de IA puede utilizarse como un canal para intercambiar instrucciones o resultados dentro de una operacion.

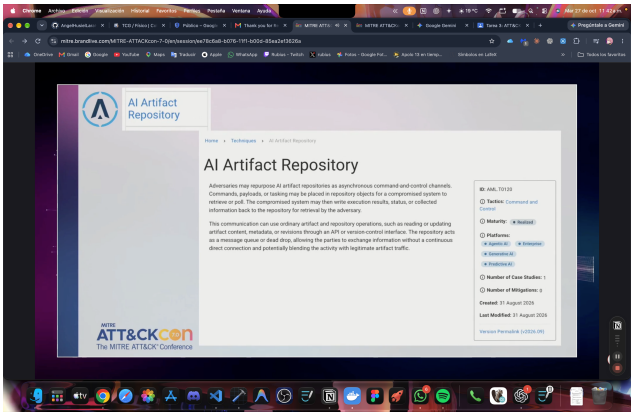

Figura 5: Ejemplo de uso de un repositorio de artefactos de IA como canal de comunicacion.

Elementos a destacar:

- Revisar el uso adversario real antes de incorporar un comportamiento.
- Distinguir lo que se puede integrar en una tecnica existente de lo que necesita otra clasificacion.
- Considerar las conexiones del sistema de IA con otros recursos de la organizacion.

2.5. Measuring ATT&CK Coverage Through Real Malware Tradecraft

El ejemplo principal fue T1055, Process Injection, que se refiere a ejecutar codigo dentro del espacio de otro proceso. La idea que mas me llamo la atencion fue que decir que detectar este ataque puede significar cosas muy distintas, dependiendo de que procedimiento se probo y de que datos se recolectaron.

Para esto se separaron varios niveles: la tecnica que se quiere estudiar, el procedimiento con el que un programa la implementa, el comportamiento que se puede observar y la capacidad de deteccion del sensor. Donde en este caso, que un procedimiento exista no significa que nuestro equipo vaya a generar toda la informacion necesaria para reconocerlo.

Despues se comparo con T1059, relacionado con interpretes de comandos y scripts. En ese caso, una linea de comandos puede aportar evidencia importante sobre la ejecucion. No obstante, para varias formas de inyeccion es necesario revisar accesos entre procesos, cambios en la memoria, permisos o cargas de componentes.

Si se prueban ocho procedimientos y solamente se pueden validar cinco, eso representa el 62.5 % de esos ocho procedimientos. No significa que se pueda detectar el 62.5 % de todos los ataques que existen.

Elementos destacods

- Distinguir entre tecnica, procedimiento, evidencia observable y deteccion.
- Medir la cobertura sobre los procedimientos que realmente se probaron.
- Volver a validar las detecciones cuando cambian las implementaciones o el entorno.

2.6. Breaking the Defenders

Ahora bien, la idea principal fue distinguir entre ocultar una accion y afectar la capacidad de las defensas. Se puede detener un servicio de seguridad, pero tambien se puede alterar lo que observa sin que el proceso desaparezca. Por lo que, ver un servicio en ejecucion no demuestra que siga entregando informacion util.

Para esto, se mencionaron ejemplos de interferencia con mecanismos de Windows que ayudan a revisar scripts o generar eventos, como AMSI y ETW. Tambien se hablo del abuso de controladores vulnerables y de cambios en la carga de librerias.

De igual forma, se revisaron casos de ransomware, donde borrar respaldos o impedir la recuperacion puede cambiar las posibilidades de respuesta de una organizacion. No obstante, se explico que no basta con esperar hasta el cifrado o hasta que aparezca la nota de rescate, por que para ese momento ya se perdieron varias oportunidades de detectar la preparacion del ataque.

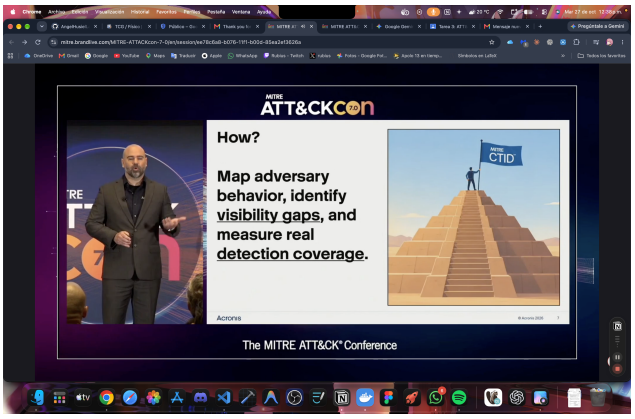

Figura 6: Mapeo del comportamiento, identificacion de falta de visibilidad y medicion de la cobertura real.

Por ultimo, se hablo de los MSP, que son proveedores que administran servicios para distintos clientes. Una configuracion que funciona para uno puede generar mucho ruido para otro, por lo que cada entorno necesita sus propios criterios. Con esto me quedo con que la cobertura tambien depende de comprobar que el defensor sigue pudiendo ver, no solamente de tener una lista de reglas configuradas.

Los elementos a destacar fueron:

- Revisar tanto los intentos de afectar una defensa como sus consecuencias.
- Investigar la perdida de telemetria con otras fuentes y con el contexto del equipo.
- Adaptar las detecciones a cada cliente y comprobar que los sensores siguen siendo utiles.

3. Ejemplos del uso de ATT&CK en la industria

1. **Ingenieria de deteccion en un SOC.** Relacionar una tecnica con los registros que se necesitan, revisar la cadena de procesos y comprobar si el SIEM genera una alerta con un caso de prueba. El SOC es el equipo que revisa y responde a este tipo de eventos.
2. **Investigacion de identidades en servicios SaaS.** Conectar accesos, cambios en cuentas y acciones dentro de las aplicaciones, para revisar la progresion de una posible intrusion y no solamente eventos aislados.
3. **Defensa de organizaciones con pocos recursos.** Priorizar las amenazas mas relevantes y los controles que se pueden mantener, dejando claro que riesgos siguen pendientes.
4. **Validacion de productos y sensores.** Probar varios procedimientos de una tecnica y revisar que evidencia se obtiene, antes de afirmar que existe cobertura.
5. **Monitoreo de las propias defensas.** Relacionar la perdida de registros con otros eventos para investigar si un control dejo de funcionar o fue afectado.
6. **Proteccion de sistemas de IA.** Utilizar el conocimiento de ATLAS y revisar su relacion con ATT&CK, considerando tambien las integraciones que conectan esos sistemas con otros recursos.

4. Experiencia general y relacion con la materia

En la practica 5 se obtuvieron credenciales, en la 6 se revisaron el sistema y la red interna, y en la 7 se utilizo un tunel SSH para acceder a otro equipo. Ahora bien, durante el evento pude ver como esas acciones tambien se pueden estudiar desde lo que tendria que observar un defensor.

Del otro lado se tendria que revisar si se registro el acceso, si se reconocio la cuenta, si aparecieron conexiones nuevas y si alguien relaciono esos datos. Esta relacion me ayudo a pensar en que registros serian necesarios para reconocer los procedimientos que realizamos durante las practicas.

Otro elemento que me llamo la atencion dentro del evento fue un ejemplo de MalChela conectado con Claude por medio de MCP. Se mostro una integracion para que una interfaz de IA pudiera utilizar herramientas del proyecto. Esto se relaciona con las preguntas sobre las conexiones de la IA con otros recursos: entre mas herramientas puede utilizar, mas importante se vuelve entender a que puede acceder y que acciones se le permiten.

Figura 7: Ejemplo de integracion de Claude con herramientas de MalChela mediante MCP.

Por ultimo, me parecio importante que varias presentaciones señalaran lo que todavia no estaba resuelto: el alcance de una futura plataforma de IA, los procedimientos que no se habian validado o las amenazas que una organizacion no puede cubrir todavia. Esto me hizo sentido por que reconocer esos limites permite saber que falta por mejorar, en lugar de asumir que todo esta completo.

5. Evidencia de participacion en el evento

Para participar me registre en la modalidad virtual de ATT&CKcon 7.0 y recibi el correo de confirmacion.

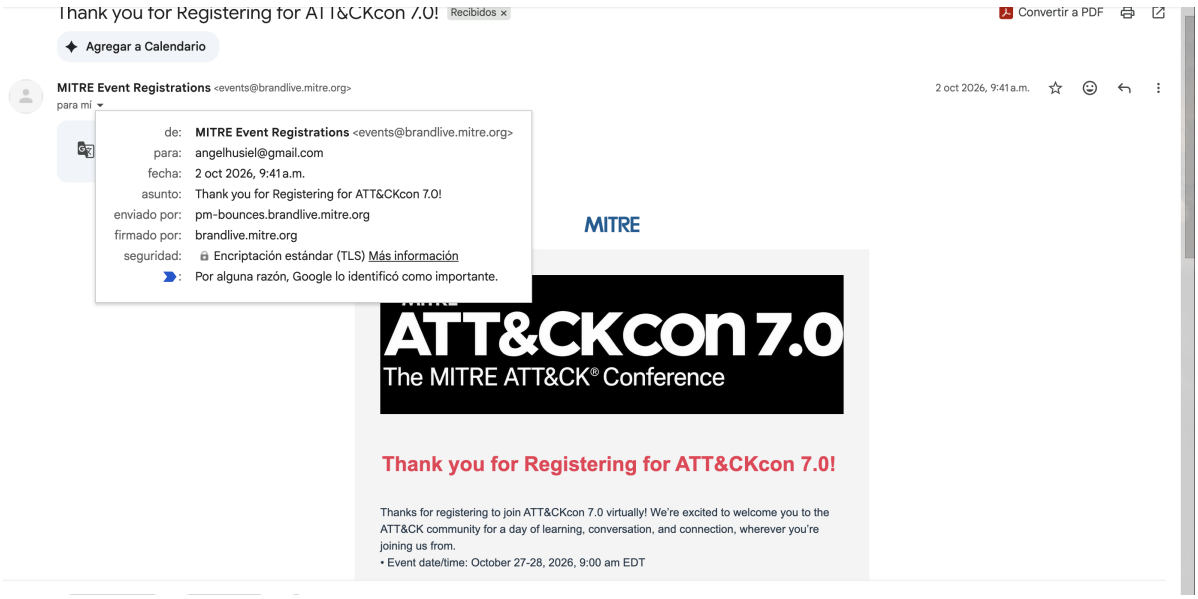

Figura 8: Confirmacion del registro a ATT&CKcon 7.0 en modalidad virtual.

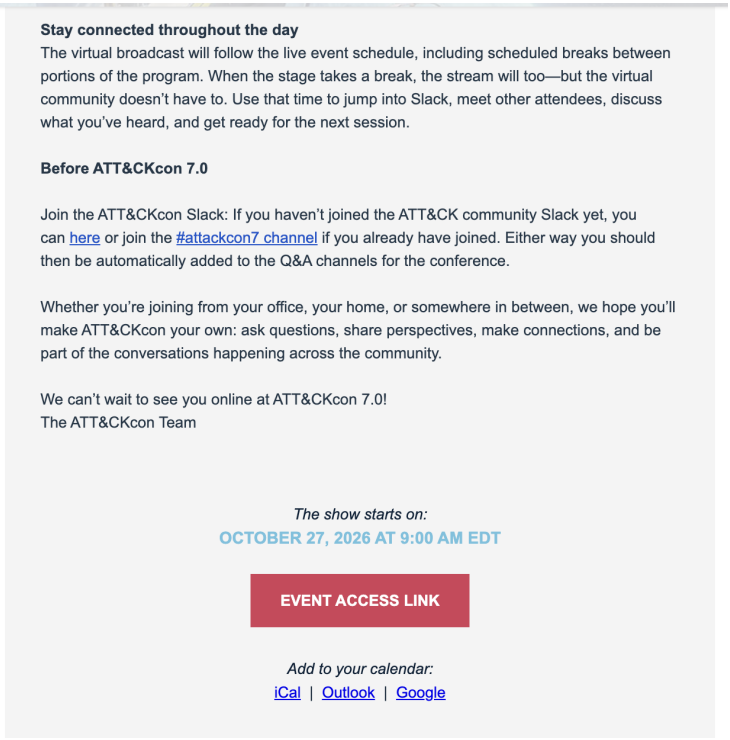

Figura 9: Informacion para el acceso virtual al evento.

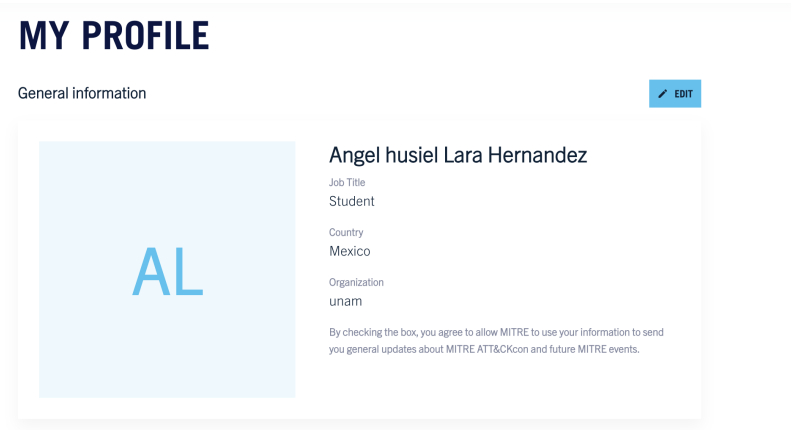

Figura 10: Perfil de participante dentro de la plataforma del evento.

Referencias

Breaking the Defenders: Measuring Defense Impairment at Scale Through MSP Telemetry. (2026, 27 de octubre).

Hamaty, R. L. (2026, 27 de octubre). The Defensible Minimum: Threat-Informed Defense When You Can't Afford the Matrix.

Measuring ATT&CK Coverage Through Real Malware Tradecraft: Beyond T1055. (2026, 27 de octubre).

MITRE ATT&CK Updates: Enterprise ATT&CK. (2026, 27 de octubre).

Multi-Tenant Kill Chain Correlation: ATT&CK-Stage Progression Scoring Across Identities and Organizations in SaaS Environments. (2026, 27 de octubre).

Obfuscated Tale: From ATT&CK Origin to Detection Today. (2026, 27 de octubre).

The MITRE Corporation. (2026, 27 de octubre). *MITRE ATT&CKcon 7.0*. Consultado el 28 de octubre de 2026, desde https://www.mitre.org/events/mitre-attackcon-7